战队名称

ohn

比赛排名

总分数：1903

学生组排名：26

总排名：33

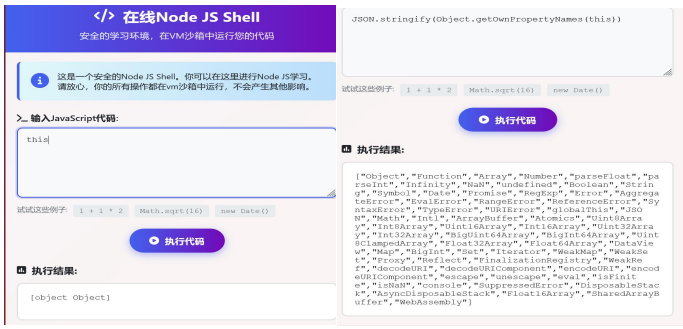
战队成员

bisct、李思睿

说明：上网查找和 ai 混着用，过程过于挤牙膏就不截图了

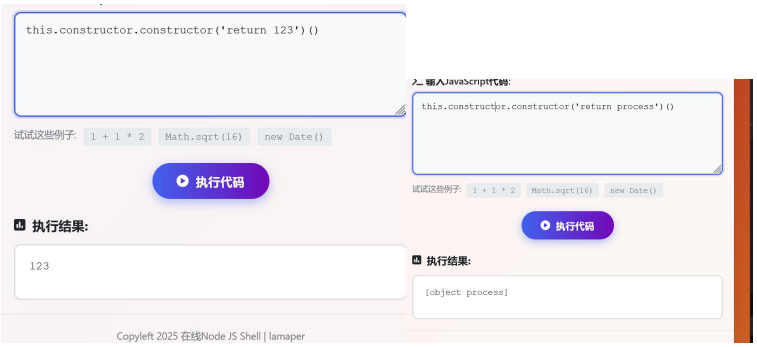
1zvm

this 返回 [object Object]说明存在一个沙箱上下文对象。列举 this 内置对象和方法

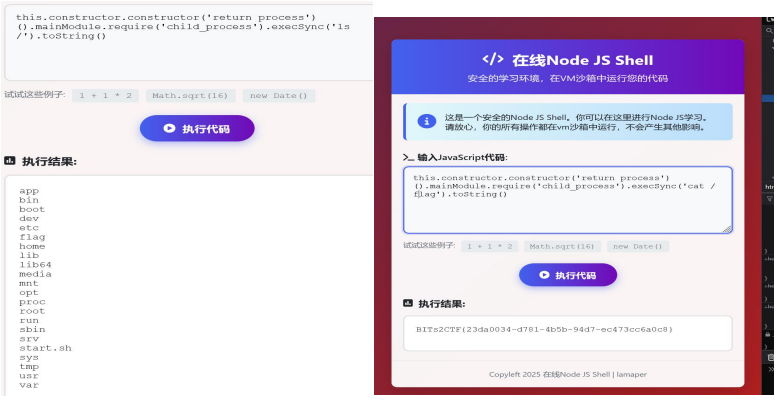


搜索基础 vm 逃逸方法并尝试：

Function 构造函数在调用时会在全局作用域中创建函数，而不是沙箱作用域。测试构造



可行，于是尝试获取 process（核心全局对象，包含进程相关信息，能调用系统函数）。获取到 process，能逃逸沙箱。然后从主模块加载子进程模块执行 ls / 并 tostring 打印



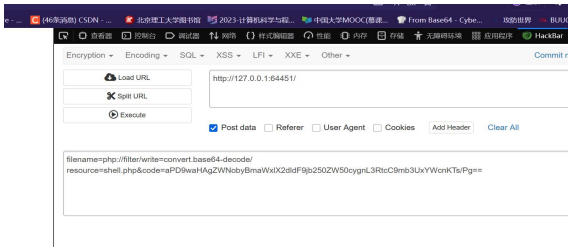
获得目录，打印 flag

Exit

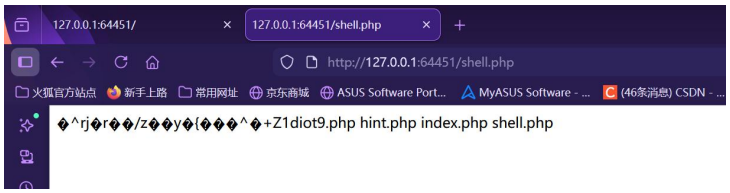
搜索 php exit 绕过 ctf 找到：[php exit 死亡绕过](#)，基本一样

原理：拼接部分利用 fileputcontent 函数容错和解析特性，让第一个参数‘filename’含 base64 写伪协议，让伪协议被执行让死亡语句所有非 base64 字符被过滤

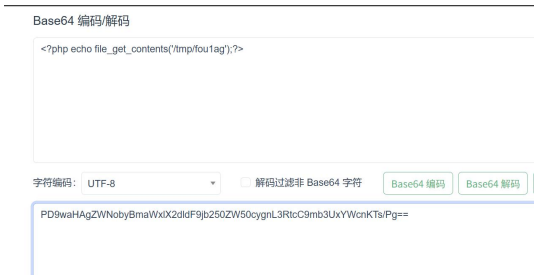
用 filename 上传 shell：
filename=php://filter/write=convert.base64-decode/resource=shell.php

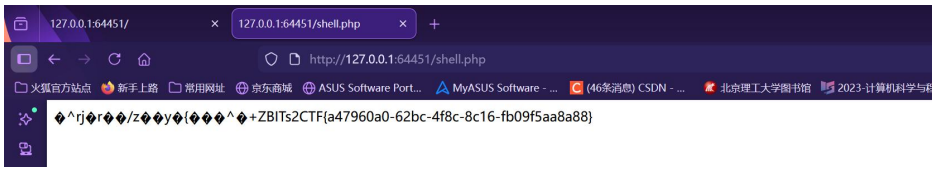


Code=base64 加密<? System（‘ls /’）?>，访问 shell.php 展示目录



挨个访问找到 flag 位置，然后上传 echo file get contents 获取 flag

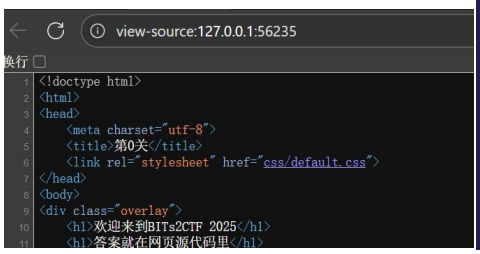


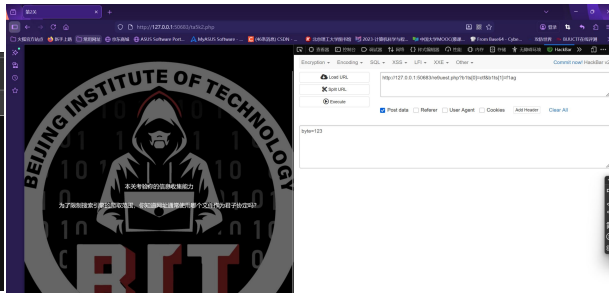


code 前要再加几个字符让 exit 语句凑成 4 的倍数，后面代码才能执行。如图乱码应该是 exit 代码 base64 解密

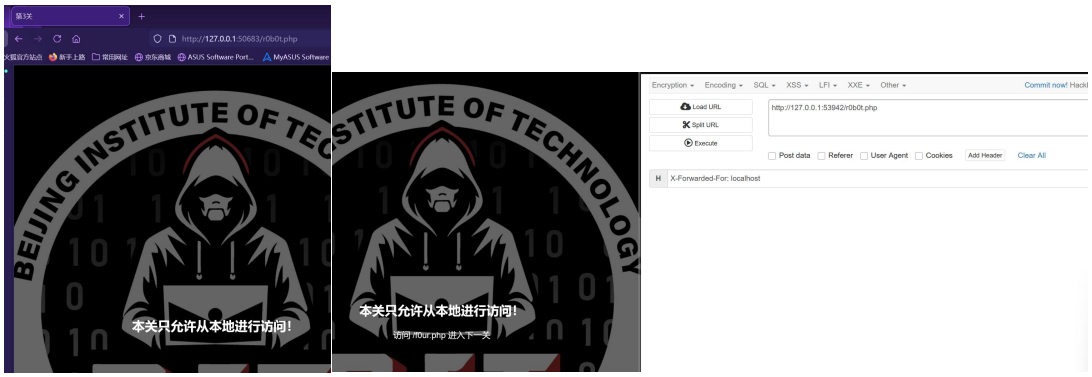
http

1、View-source:。2、Hackbar 传参





3、访问 robots.txt 反爬虫协议。4、增加代理解析头，第一个参数设为 localhost



5、base64 解码

Noobunser

unserialize()结束触发_destruct()输出$this->bits2ctf

令$this->bits2ctf 为 anything 对象

Echo 对象触发 anything 的__toString()

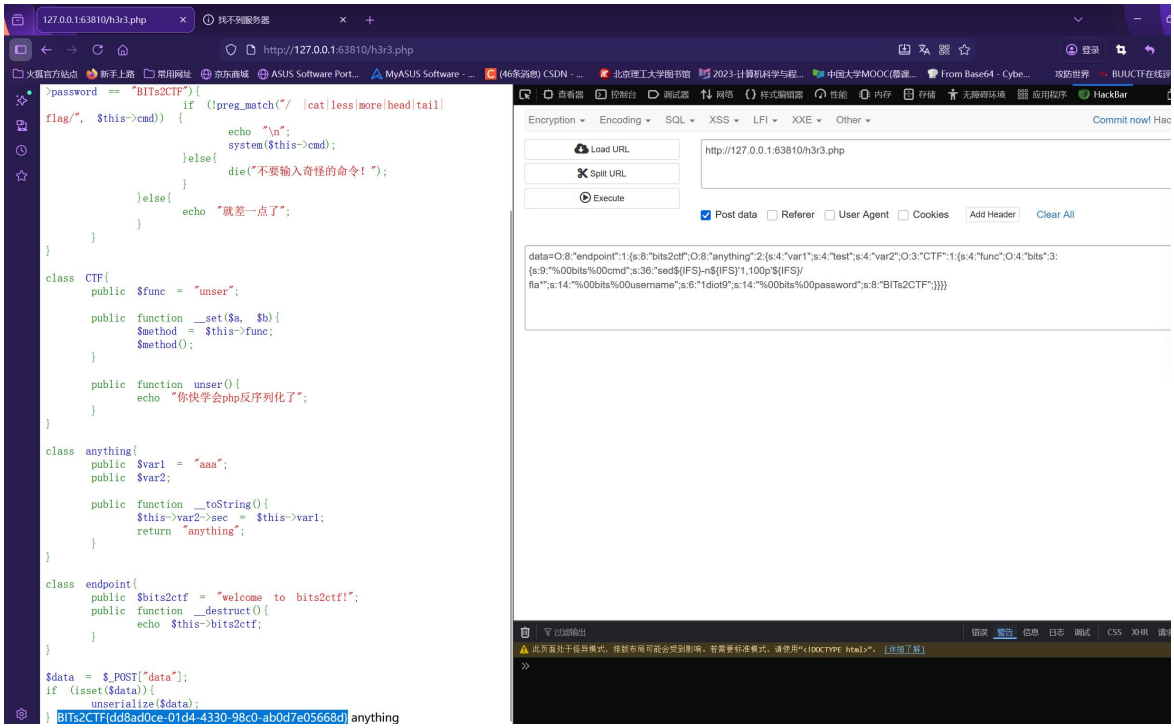
__toString()中有$this->var2->sec = $this->var1

令 var2 为 CTF 类没有 sec 属性，进而触发 CTF 的__set()方法

__set()中令$this->func()=bits 类触发 bits 的__invoke()

data=0:8:"endpoint":1:{s:8:"bits2ctf";0:8:"anything":2:{s:4:"var1";s:4:"test";s:4:"var2";0:3:"CTF":1:{s:4:"func";0:4:"bits":3:{s:9:"%00bits%00cmd";s:x:"*";s:14:"%00bits%00username";s:6:"1diot9";s:14:"%00bits%00password";s:8:"BITs2CTF";}}}}

Cmd 执行命令。Cmd=ls 没有 flag，于是匹配查找 fla*，搜索询问一番后可用${IFS}代替空格，用 sed -n '1,100p'流编辑器匹配并打印。



签到题